00

AUDITORÍA

Índice & Resumen

Entregables, hallazgos, evidencia y estado tras la auditoría completa.

Reporte maestro · 4 tests

25 skills verificados | 22 fixes aplicados | 6 commits

PROYECTO
inventory-app · Angular 22

FECHA
Septiembre 2026

METODOLOGÍA
agent-skills · OWASP · WCAG 2.1

PENDIENTE lint | PENDIENTE build | PENDIENTE test

PENDIENTE evidencia

Reporte maestro — Auditoría de `inventory-app` con agent-skills

Fecha: 2026-09-10 **Proyecto:** `C:\Users\juanca\Documents\app\inventory-app` (Angular 22, SPA cliente-only, sin backend)

---

0. Instalación de agent-skills (verificación)

- Fuente: https://github.com/addyosmani/agent-skills
- Instalados globalmente en `~/.config/opencode/skills/`:
  - **25 skills** (cada uno con su `SKILL.md`) → verificado 25/25
  - Carpeta `references/` compartida (checklists) → copiada
- Válido: `test-driven-development`, `spec-driven-development`, `security-and-hardening`, `performance-optimization`, `code-review-and-quality`, `code-simplification`, `frontend-ui-engineering`, `debugging-and-error-recovery`, `planning-and-task-breakdown`, etc.
- Sesión actual: los skills se descubren al **iniciar opencode** (por eso trabajé leyendo sus `SKILL.md`/referencias directamente); en la próxima sesión se cargan solos.
- Recomendación: un `AGENTS.md` en el proyecto con el mapeo intención→skill para activación automática.

1. Resumen ejecutivo

Test	Carpeta	Alcance	Hallazgos	Fixes aplicados	Estatus
test1	`test/test1/`	Seguridad / hardening	2 alta, 2 media, 2 baja, 2 info	7 cambios en 8 archivos	✅ lint+build+audit
test2	`test/test2/`	Performance	2 media, 2 baja, 2 info	3 cambios en 8 archivos	✅ lint+build
test3	`test/test3/`	Calidad / code review	1 correctitud, 1 rendimiento, 3 deuda	6 cambios en 9 archivos (+prettier)	✅ lint+build+prettier
test4	`test/test4/`	Accesibilidad WCAG AA	5 fallos AA + 2 veredictos OK	6 cambios en 7 archivos	✅ lint+build+prettier

Total: 22 cambios en ~20 archivos. Todos los reportes individuales incluyen hallazgos detallados, evidencia (`evidence/`) y ledger de intentos/descartes.

2. Hallazgos destacados

test1 — Seguridad

- **CSV formula injection** en exportaciones (OWASP): neutralizado con prefijo `'`.
- **Upload de imágenes**: allowlist de MIME + rechazo en fallback de canvas (antes devolvía data URL crudo).
- **CSP** añadido (meta) + referrer policy.
- **Validación de forma** al leer `localStorage` (guards `isProduct` / `isMovement` / `isSupplier`).
- **Límite de 5 MB** en importación CSV.
- `npm audit`: **0 vulnerabilidades** (556 deps).
- Info: datos en `localStorage` sin cifrar (cliente-only, documentado).

test2 — Performance

- OnPush añadido a **dashboard, products, reports** (páginas más pesadas).
- `barColor()` → lookup `catColors[c.cat]` (sin llamadas a método en template).
- `loading="lazy" decoding="async"` en miniaturas de listas.
- Bundle inicial: **77.8 kB transfer** (target < 200 kB gzip) ✅. Lazy routes OK.

test3 — Calidad

- **Leak corregido**: suscripción `valueChanges` sin unsubscribe → `takeUntilDestroyed`.
- **Intl formatters memorizados** (1 por tipo en vez de por celda/render).
- **Dead code eliminado**: `imageError`, `gaugeC`.
- **Dedup**: `ProductService.byIdIndex` y `SupplierService.byIdMap` (4 sitios consolidados).
- **Prettier**: 46 archivos que no pasaban `--check` normalizados.
- Nota: `ng test` **no tiene runner configurado** (documentado; no configurado por decisión del usuario).

test4 — Accesibilidad (WCAG 2.1 AA)

- **Trampa de Tab + restauración de foco** en `confirm-dialog` (2.1.2 / 2.4.3).
- **Skip-link** "Saltar al contenido" (2.4.1).
- **Contraste corregido**: `--muted` (~2.8:1→5.1:1), `--amber` (~3.9:1→5.3:1), `--violet` del CTA (4.3→5.6:1).
- `th scope="col"` en las 3 tablas (1.3.1).
- Ya solidos de base: labels, aria-live, aria-pressed, role=alertdialog, reduced-motion.

3. Evidencia por test

Cada carpeta `test/testX/` contiene:

- `REPORT.md` — hallazgos, fixes, verificación y ledger

- `evidence/` — salidas reales de commandos (`npm audit --json`, `npm run build`, `npm run lint`, `prettier --check`)

4. Línea de tiempo git

Commit	Descripción
`65c8c6e`	Baseline snapshot before audit (git init + estado original)
`…test1`	Security hardening
`…test2`	Performance
`…test3`	Code quality + prettier normalize
`…test4`	Accessibility WCAG AA
`master-report`	Este reporte

5. Riesgo residual y recomendaciones

1. **Backend + auth** si la app se comparte: hoy 100% cliente (limitación arquitectural documentada).
2. **Runner de tests** (`ng test`): configurar Vitest + algunos specs de servicios/utilidades (fuera de alcance).
3. **Auditoría automatizada (axe-core)** en CI para mantener las mejoras de accesibilidad.
4. **Virtualización** de listas si el catálogo supera unos miles de SKUs.
5. Servir en **HTTPS** para `crypto.randomUUID()` y para un despliegue real seguro.

6. Cierre

Auditoría completa en 4 tests con skills del repo `agent-skills`, fixes aplicados y verificados (lint + build + prettier + audit), evidencia guardada y git con commits atómicos por test. El código queda en un estado más seguro, más rápido y accesible, todo reversible vía `git revert`/`reset` al baseline `65c8c6e`.

Entregables

01 **Seguridad & Hardening**
Threat model, dependencias, manejo de inputs, CSP y almacenamiento local.
test/test1/REPORT.md

02 **Performance Web**
Carga inicial, change detection, renderizado de listas e imágenes.
test/test2/REPORT.md

03 **Calidad & Code Review**
Revisión por 5 ejes, simplificación, deuda técnica y formato.
test/test3/REPORT.md

04 **Accesibilidad WCAG 2.1 AA**
Teclado, lectores de pantalla, focuseado, contraste y semántica.
test/test4/REPORT.md